

# Linux CVE workgroup

# Context

- Since Feb '24, Linux is its own CNA
- [Linux Kernel CVEs, What Has Caused So Many to Suddenly Show Up? - Greg Kroah-Hartman @ CNCF](#)
- CVE volume has significantly increased
  - Before: ~20/month
  - After: ~60/**week**
  - 1300+ filed from past commits

# Challenge

- How do we triage them all?
- Different challenges for different players in the community
- For a cloud provider:
  - Can't reboot machines
  - Decision in {ignore, (expedite) backport, livepatch}
- Applicability depends on threat model, exploitability, permissions, etc.
- Is there space for collaboration?

# Outcome from LPC 2024

- Very high interest demonstrated by many different entities
  - Google, Microsoft, Canonical, Oracle, Red Hat, SUSE, Amazon...
  - Intention to collaborate on community-powered analysis
- CNA team is open to add our analyses to CVE records
- Threat models can be different, but the baseline analysis stays the same
- No engagement should be demanded to maintainers

# Linux CVE workgroup

- Idea: share basic CVE analysis with the community
  - Following a threat-model agnostic template
  - Everyone is already doing this work independently!
    - Reduce toil
    - Improve accuracy
- <https://github.com/cloud-lts/linux-cve-analysis>
- Bi-weekly meetings
- #linux-cve-workgroup IRC channel on libera.chat

# Example – CVE-2024-46800

reachability: Local

memory\_corruption: yes

bug\_class: Use-After-Free

impact: LPE

privileges\_required: no

notes: An exploit has been submitted as part of kCTF (exp192). Privileged capabilities (CAP\_NET\_ADMIN) in user namespace are sufficient to exploit the bug.

author: Google

# Example – CVE-2024-46800

reachability: Local

*Some may stop here*

memory\_corruption: yes

bug\_class: Use-After-Free

impact: LPE

*Some may worry here*

privileges\_required: no

notes: An exploit has been submitted as part of kCTF (exp192). Privileged capabilities (CAP\_NET\_ADMIN) in user namespace are sufficient to exploit the bug.

author: Google

*Some may stop here*

# What's working?

- Collaboration is recognized as essential in this space
- Lots of important stakeholders actively participate
- 704 CVEs analyzed
- Active discussions over progressive improvements
  - Leveraging LLMs
  - Focusing only on high-severity issues
  - Etc.



# What can be improved

- **Latency**

- Analyses pushed in batches some time after CVEs were published
- In the meantime, everyone had to triage them already

- **Throughput**

- Only a small subset of CVEs is analyzed by the group

- Alignment challenges

- Our template vs CVSS

# What's next?

- To address latency and throughput, we have to integrate this with our internal processes
- AI to the rescue?
  - AI-powered analysis are becoming better and better, to the point that we should start sharing them
  - LLMs can also help with subtasks (e.g., translate internal analysis with upstream-able one)